

Cybernetic Security

Tomáš Sochor
Dept. of Informatics
Faculty of Business and Economics, Mendel University

Secure communication
of services

March 2026

● MENDEL
● Faculty
● of Business
● and Economics

Lecture Agenda

PKI:

certificates

encrypted communication

Digital signatures

High availability tools:

anycast

DNS

CDN

Intro: Certificates

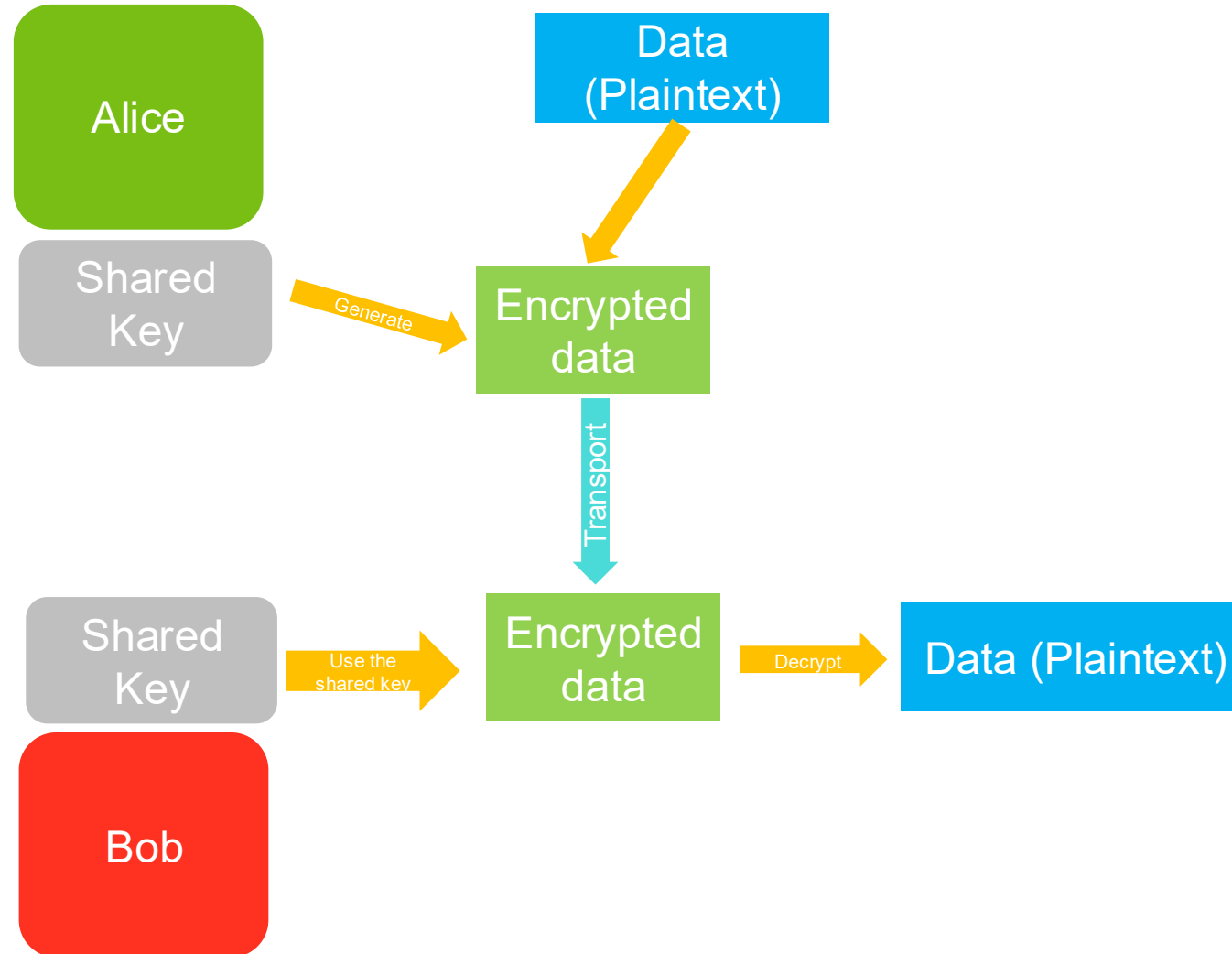
■ Certificate:

- (one type of) a tool how to publish a public key:
 - Containing public key of a holder (a person/a server),
 - Securely signed by the issuer (certification authority).

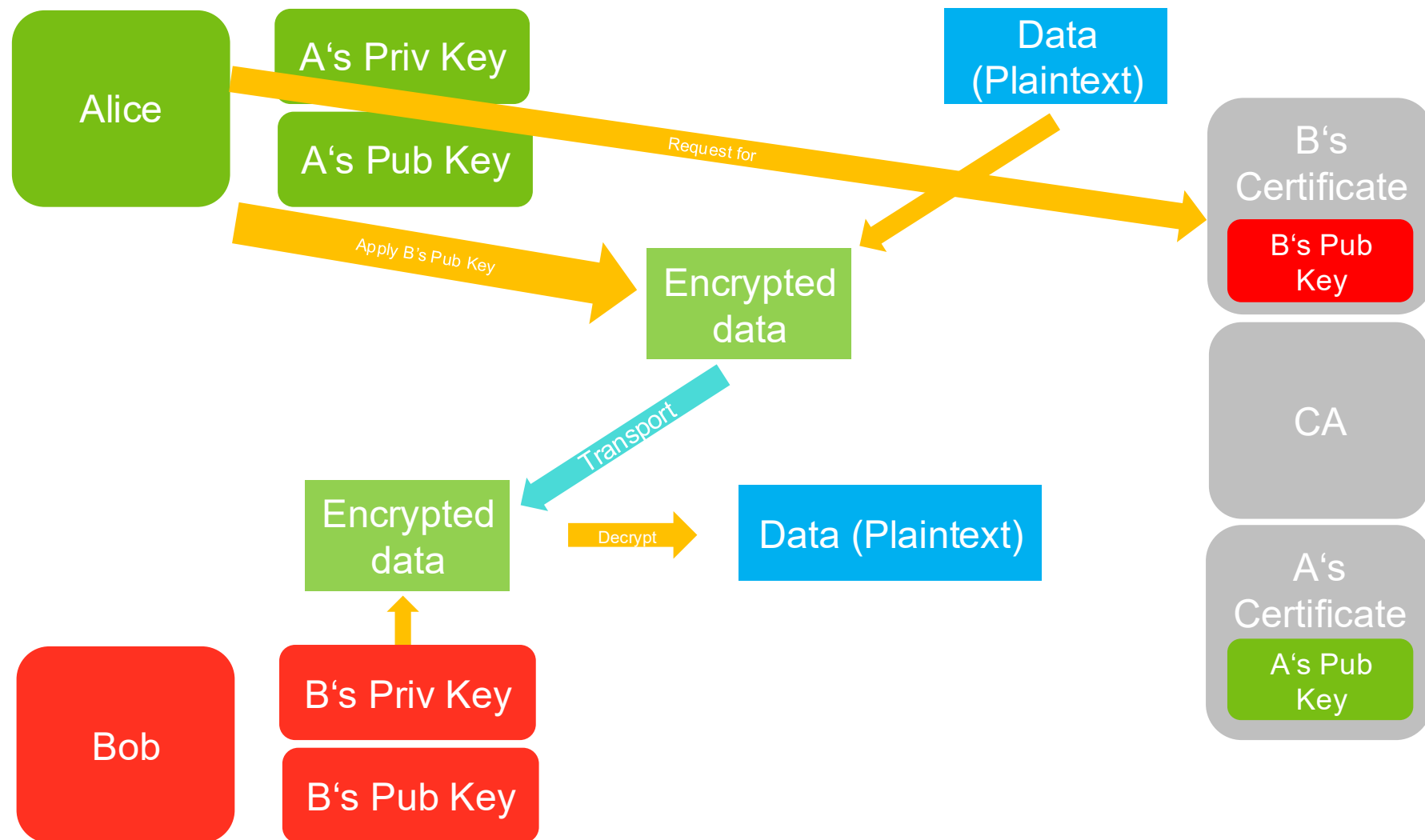
■ Why are certificates needed?

- Trustful public key publication.
 - Otherwise, a public key should be considered unreliable (missing holder authentication).
- There are alternatives:
 - PGP (network of shared trust),
 - Face-to-face handover,
 - But not flexible enough.

Shared Key Cryptography – Symmetric Encryption



Public Key Cryptography – Encryption



Certificates: Algorithms

■ RSA:

- The first algorithm published in 1977
- Based on integer number factorization (to prime factors):
 - Easy to multiply two primes
 - But finding the two primes from the product is difficult. $1559 \times 2003 = 3\,122\,677$
- In practice, integers with e.g. 100 decimal digits are used.

■ Elliptic curve cryptography (ECC):

- Finding a discrete logarithm of an elliptic curve for given (known) base point.
 - Shorter keys provide equivalent privacy to longer keys e.g. for RSA.
 - Can be also used both for signatures (ECDSA), key exchange (ECDH)...
- Other exist, e.g. ElGamal.

1 Public Key Infrastructure

- PKI is a software system (IS) covering the following features:
 - Certificate issuing (creation and distribution) for:
 - End-users,
 - Servers.
 - Certificate storage and verification (including search):
 - Trusted certificate repository,
 - When a certificate is used, its verification is necessary.
 - Revocation of certificates (on request):
 - Usually in case of a private key loss.
 - Certificate Revocation List (CRL) is published periodically.
- All above operations are conditioned by user authentication.

Encrypted communication

- There are several ways of securing communication with certificates:
 - TLS (used in HTTPS),
 - Digital signatures,
 - SSH (key pairs are used instead of certificates),
 - ...

TLS Protocol (Transport Layer Security)

■ TLS:

- Successor of SSL for securing communication over TCP (below HTTP).
- Client-Server negotiation procedure:
 1. Client establishes a TCP connection to a server supporting TLS
 - e.g. TCP port 443 of a web server,
 - Immediately after, a request to start an encrypted connection is sent:
 - Together with a set of supported methods of encryption (both symmetric and asymmetric) and hashing.
 2. The server compares the list of supported methods with its own and chooses a suitable set, and
 - Sends its certificate to the client.
 3. The client verifies the certificate validity and trust.
 4. The client establishes a session key for symmetric encryption:
 - Diffie – Hellman key exchange is used (exchanging data encrypted using PrivKey): in TLS version 1.3.
 - In previous versions, a random number of suitable length, and encrypts it with the server public key (from certificate).

TLS versions

- TLS 1.0 – almost identical to SSL 3.0
 - RFC2246 (1999)
 - Little differences intentionally introduced only for the purpose of avoiding security level downgrade.
- TLS 1.1
 - RFC4346 (2006)
- TLS 1.2
 - RFC5246 (2008)
 - E.g. adding AES.
- TLS 1.3
 - RFC8446 (Oct 2018)

SSH – Secure SHell

- Protocol for encrypted remote connection:
 - Using various (selectable) cryptographic techniques.
 - Open-source (OpenSSH).
- Public/private key pair instead of a certificate are used.
- Simplest usage: Replacement of telnet (command-line interface to a server),
- Other applications:
 - SSH tunneling: encrypted transmission of any data from local socket to remote one.
 - E.g. for remote desktop connection.
 - Details e.g. <https://www.concordia.ca/ginacody/aits/support/faq/ssh-tunnel.html#:~:text=SSH%20tunneling%2C%20or%20SSH%20port,machine%20via%20a%20secure%20channel>.

2 Digital Signature

- Replacement of common paper-based signature:
- Main properties:
 - Authentication of signee,
 - Keeping the signed document integrity,
 - Non-repudiation.

Electronic Signature

Special type of Digital signature, specified by law (in the EU).

It applies numerous cryptography mechanisms (encryption, hashing).

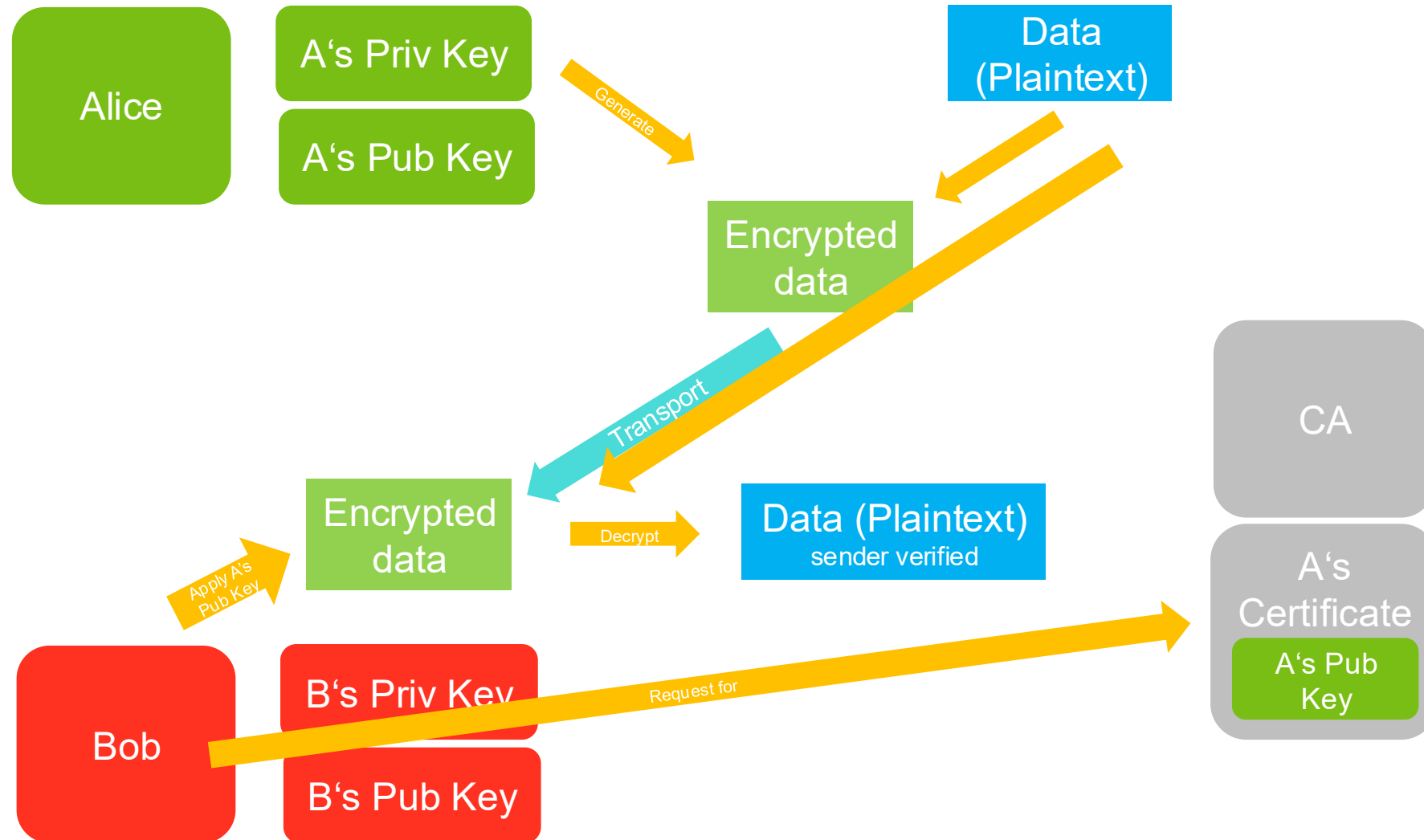
Mostly based on personal certificate (in EU, this is the only option at present).

Several aspects:

- Technical
 - Regarding the personal certificate used.
- Legislative
 - How the signature can be verified to be related to the signee.
- Main applications:
 - Signing documents,
 - Signing messages,
 - Signing code (applications).

Electronic Signature

Public Key Cryptography Application



3 High Availability

- Can a service be ALWAYS available?
 - Usually not 100% but High Availability can increase the availability.
- Metric of availability:
 - Uptime ratio (in total time):
 - $uptime\ ratio = \frac{uptime}{total\ time}$
 - 99.999% is considered as High Availability.
- Why 100% cannot be reached?
 - Some downtime is always necessary (e.g. maintenance, upgrades etc.)
 - 99.999% means only 0.0001% can be downtime.
 - In a year, it is 52 minutes and 30 seconds of allowed downtime.

High Availability – Cont'd

- Standard approach to HA:
 - Elimination of Single Points of Failure (SPoF):
 - with high impact, i.e.:
 - to many users, or
 - to high amount (share) of communication.
- Types of SPoF:
 - Infrastructure (central switch/router/firewall..)
 - Shared resources (disks, printers, ...)
 - Power feeding of critical components,
 - Single servers for services (DHCP, DNS, ...).

Critical SPoFs

- Infrastructure:
 - including power feeding, cooling, A/C, ...
- DNS servers,
- DHCP servers,
- Web servers.
- SPOF elimination:
 - Anycast addressing,
 - Server redundancy (hot-swaps etc.),
 - Load balancing.

Anycast

- Anycast is a mechanism allowing to communicate with one of the groups of target nodes (usually servers).
 - Based on IP address:
 - for IPv4, BGP support is required.
 - in IPv6, anycast addresses are supported:
 - in each /64 subnet, the last 7 bits of the interface ID (last 64 bit of the address) are reserved for anycast ID.
 - To recognize the address as anycast, the 7th bit of 1st byte in interface part must be set to 0:
 - e.g. 2000:A:B:C::/64 ... anycast address for all routers in the subnet.

Anycast Address Delivery

- Anycast address must be assigned to a network device (e.g. a router):
 - not to a host.
- Anycast address may not be used as sender address in any packet:
 - Even a device in an anycast group sends packets with its own unicast address.
- Packet sent to anycast address is delivered to one anycast group member
 - The nearest to the sender.
- Anycast addresses can be used as an efficient solution to deliver packets to e.g. one of more DNS servers.

DNS Server Multiplication (Redundancy)

- DNS is a part of critical servers:
 - Translating FQDN to IP addresses is critical for all users/services:
 - Single DNS server represents a SPoF.
- Single DNS server can be multiplied by:
 - Additional (backup) DNS server in the same network,
 - Additional DNS server in another network:
 - Existing DNS server is another network,
 - Multiple DNS servers acting as DNS service for multiple networks,
 - Cloud solutions (e.g. Cisco Umbrella).

DNS Security

- DNS contents should be protected:
 - On servers, and namely
 - When sent over networks:
 - Spoofing of an incorrect IP address in the DNS response could result in MITM attack.
- DNS protocol does not include any protection:
 - Sent over UDP,
 - No authentication,
 - No encryption.

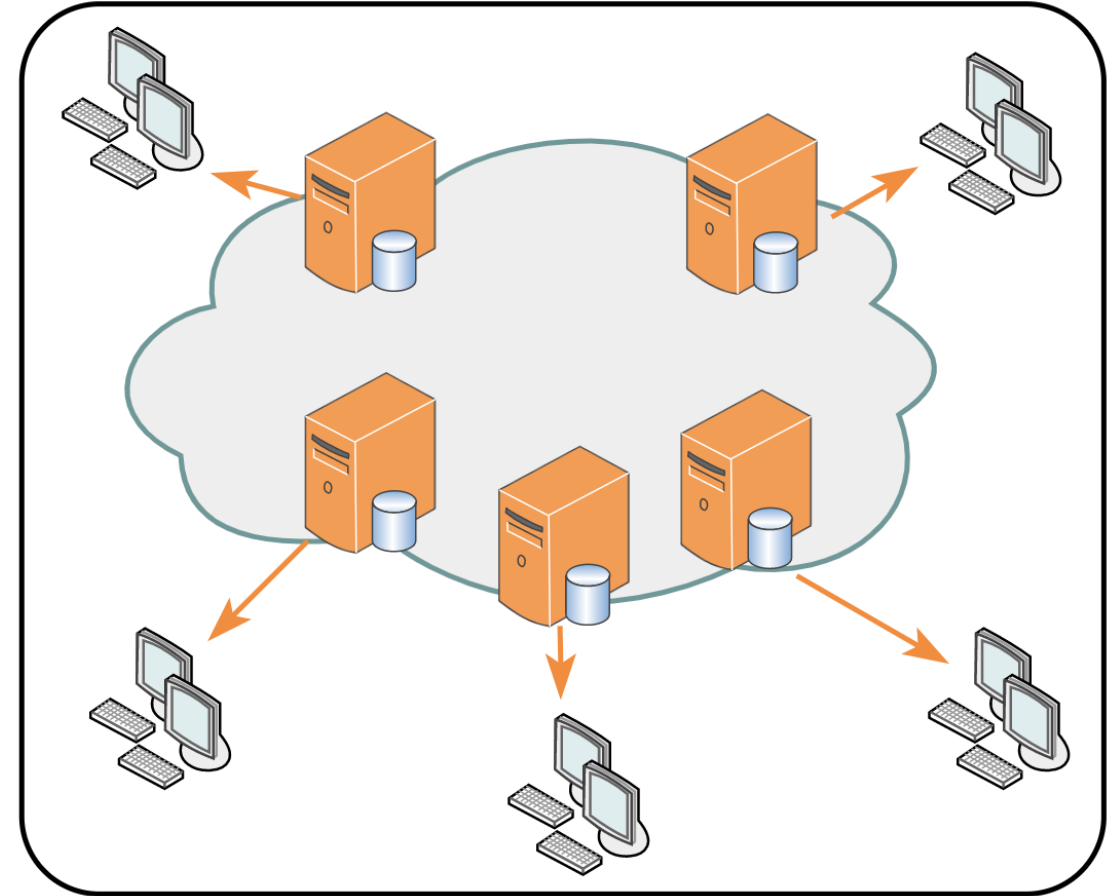
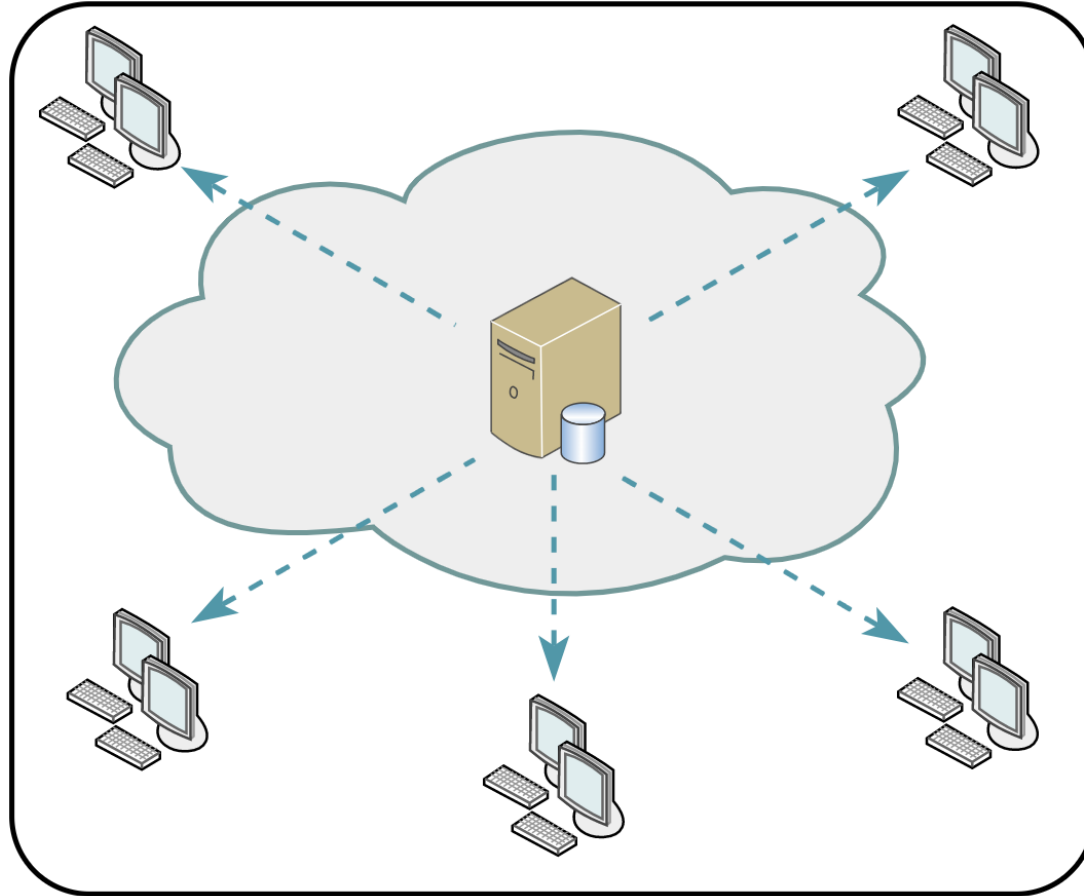
DNS Security: Secure Protocols

- DNSSEC:
 - For secure communication between DNS servers:
 - Primarily for root DNS server authentication.
- DNS over TLS,
- DNS over HTTPS:
 - 2 DNS security solutions for endpoints.

Content Delivery Networks

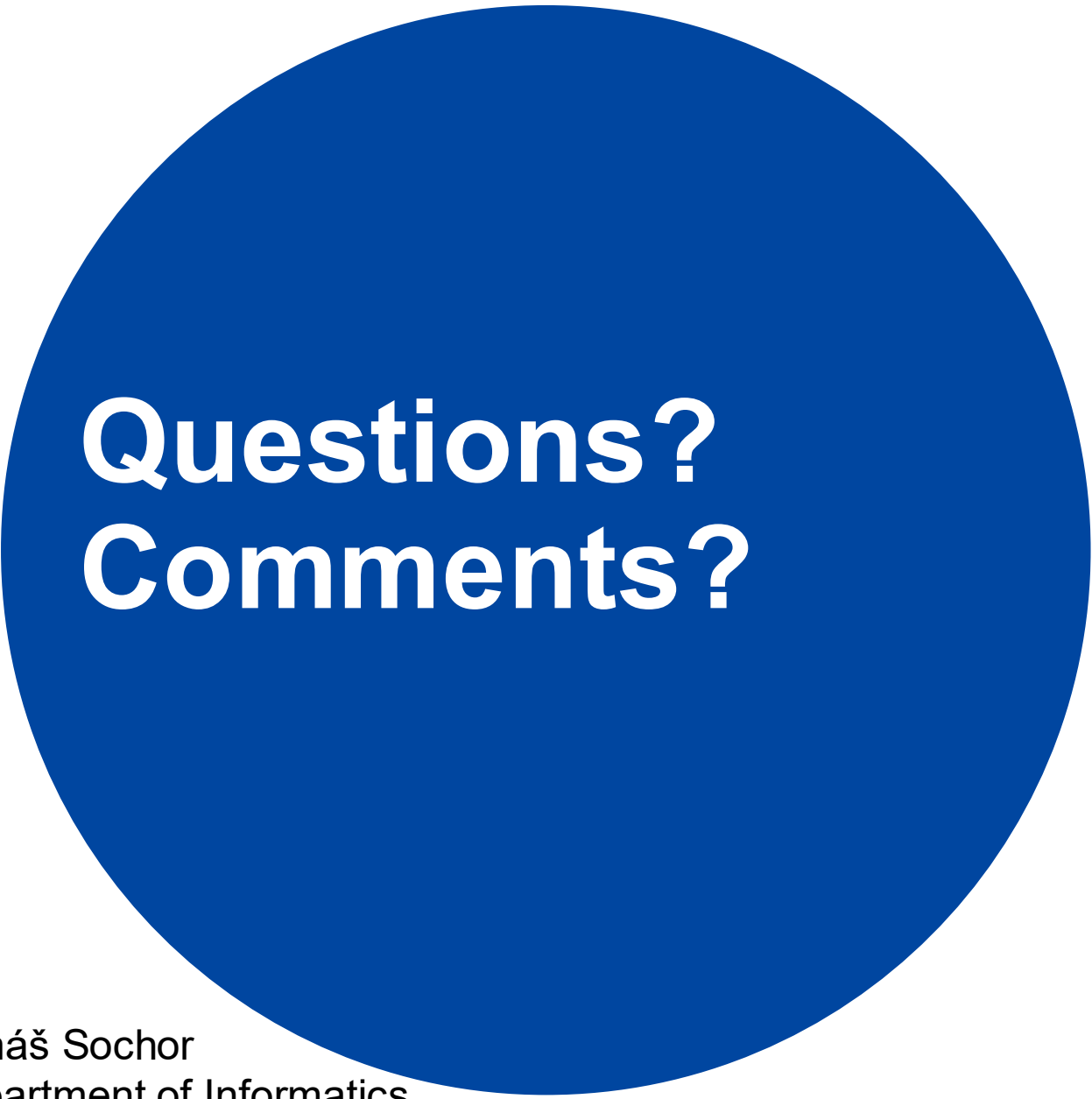
- CDN is a tool for providing a service by multiple isolated servers:
 - e.g. a web page with heavy traffic load, or
 - IS with thousands of users worldwide.
- CDN is a network (geographically distributed) of proxy servers and data centers.

Content Delivery Networks – Example



Content Delivery Networks

- CDN goals:
 - SPoF elimination,
 - Improving response time,
 - Better scalability than a single server.



Questions? Comments?

Tomáš Sochor
Department of Informatics
tomas.sochor@mendelu.cz

● MENDELU
● Faculty
● of Business
● and Economics



Thank you for your attention

Tomáš Sochor
FBE MendelU
tomas.sochor@mendelu.cz

● MENDELU
● Faculty
● of Business
● and Economics